

Ex:1**Governance & Regulation****Date: 18.07.2026****Aim:**

To explore the policies and frameworks used to regulate cybersecurity in an organisation and understand their role in protecting information and systems.

Task:**Task 1: Introduction**

I am ready to start the room.

No answer needed

✓ Correct Answer

Task 2: Why is it important?

Answer the questions below

A rule or law enforced by a governing body to ensure compliance and protect against harm is called?

Regulation

✓ Correct Answer



Health Insurance Portability and Accountability Act (HIPAA) targets which domain for data protection?

Healthcare

✓ Correct Answer

Task 3: Information Security Frameworks

The step that involves monitoring compliance and adjust the document based on feedback and changes in the threat landscape or regulatory environment is called?

Review and update

✓ Correct Answer



A set of specific steps for undertaking a particular task or process is called?

Procedure

✓ Correct Answer

Task 4: Governance and Risk Compliance (GRC)

Answer the questions below

What is the component in the GRC framework involved in identifying, assessing, and prioritising risks to the organisation?

Risk Management

✓ Correct Answer



Is it important to monitor and measure the performance of a developed policy? (yea/nay)

yea

✓ Correct Answer

Task 5: Privacy and Data Protection

Answer the questions below

What is the maximum fine for Tier 1 users as per GDPR (in terms of percentage)?

4

✓ Correct Answer

In terms of PCI DSS, what does CHD stand for?

cardholder data

✓ Correct Answer



Task 6: NIST Special Publications

Per NIST 800-53, in which control category does the media protection lie?

Physical

✓ Correct Answer



Per NIST 800-53, in which control category does the incident response lie?

Administrative

✓ Correct Answer

Which phase (name) of NIST 800-53 compliance best practices results in correlating identified assets and permissions?

Map

✓ Correct Answer

Task 7: Information Security Management and Compliance

Which ISO/IEC 27001 component involves selecting and implementing controls to reduce the identified risks to an acceptable level?

Risk treatment

✓ Correct Answer

In SOC 2 generic controls, which control shows that the system remains available?

Availability

✓ Correct Answer

Task 8: Conclusion

Answer the questions below

Click the **View Site** button at the top of the task to launch the static site in split view. What is the flag after completing the exercise?

THM{SECURE_1001}

✓ Correct Answer

Result:

Successfully gained knowledge of cybersecurity governance, risk management, and regulatory compliance, helping organisations maintain a secure and controlled environment.